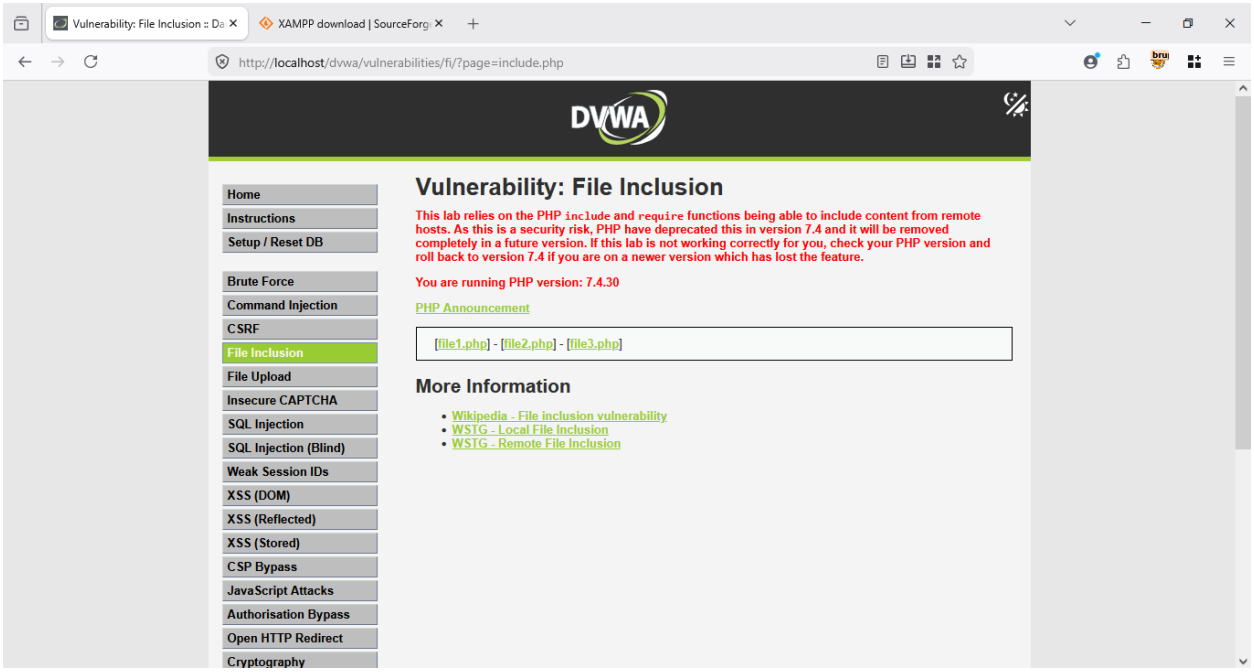
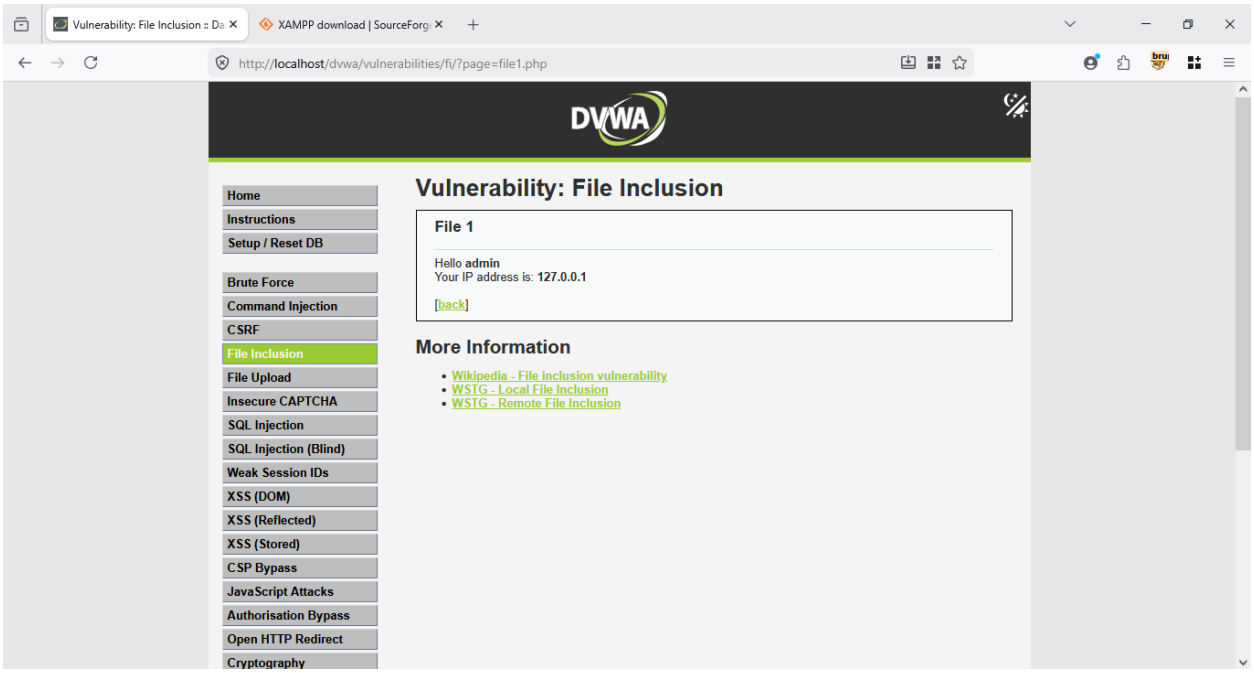
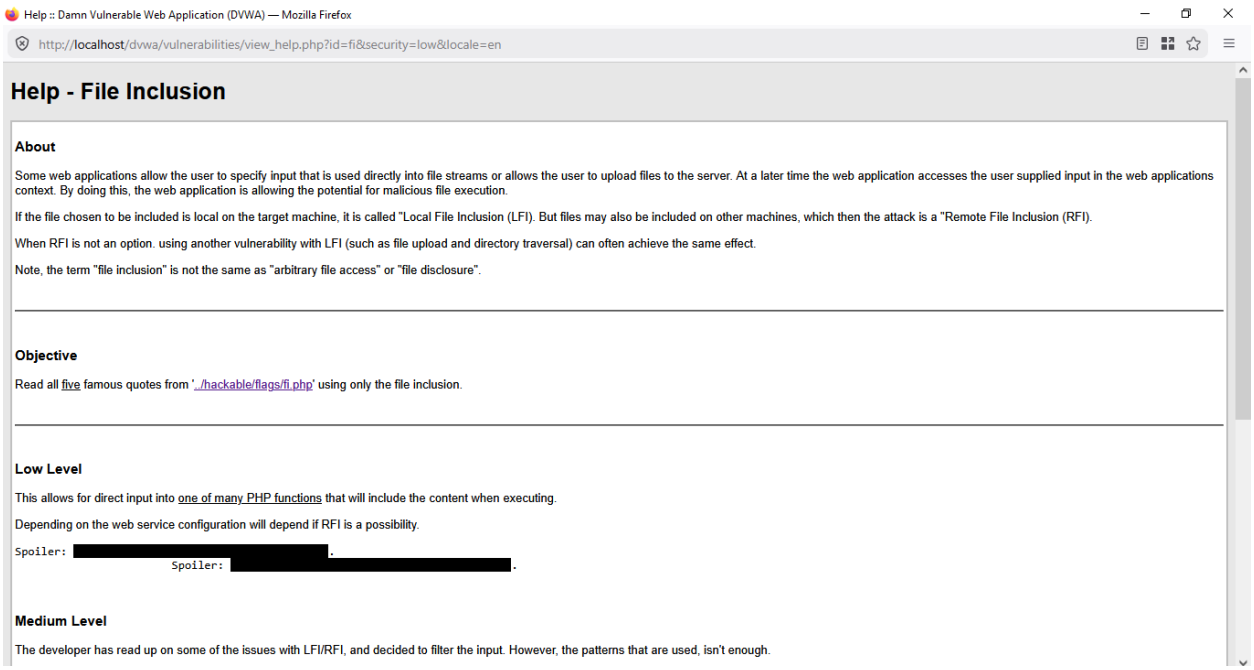
File inclusion

File inclusion adalah kerentanan keamanan web di mana aplikasi mengizinkan penyerang memanipulasi input (seperti parameter URL) untuk memaksa server membaca atau mengeksekusi file yang tidak seharusnya, termasuk file sensitif pada server. Celah ini muncul akibat input pengguna tidak difilter dengan baik sebelum digunakan dalam fungsi pemanggilan file, memungkinkan akses data ilegal hingga eksekusi kode berbahaya.

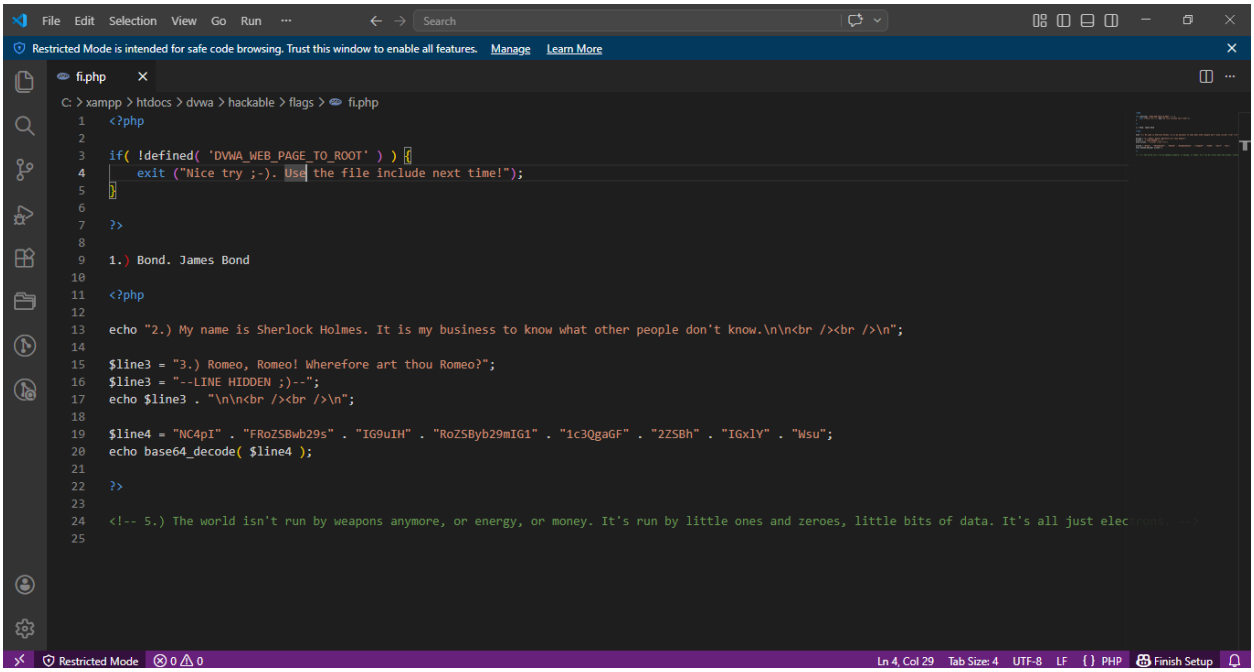






Kita bisa lihat isi dari file fi.php merupakan tujuan kita untuk bisa mengakses folder …/hackable/flags/fi.php dimana di dalam file fi.php terdapat 5 Quote.

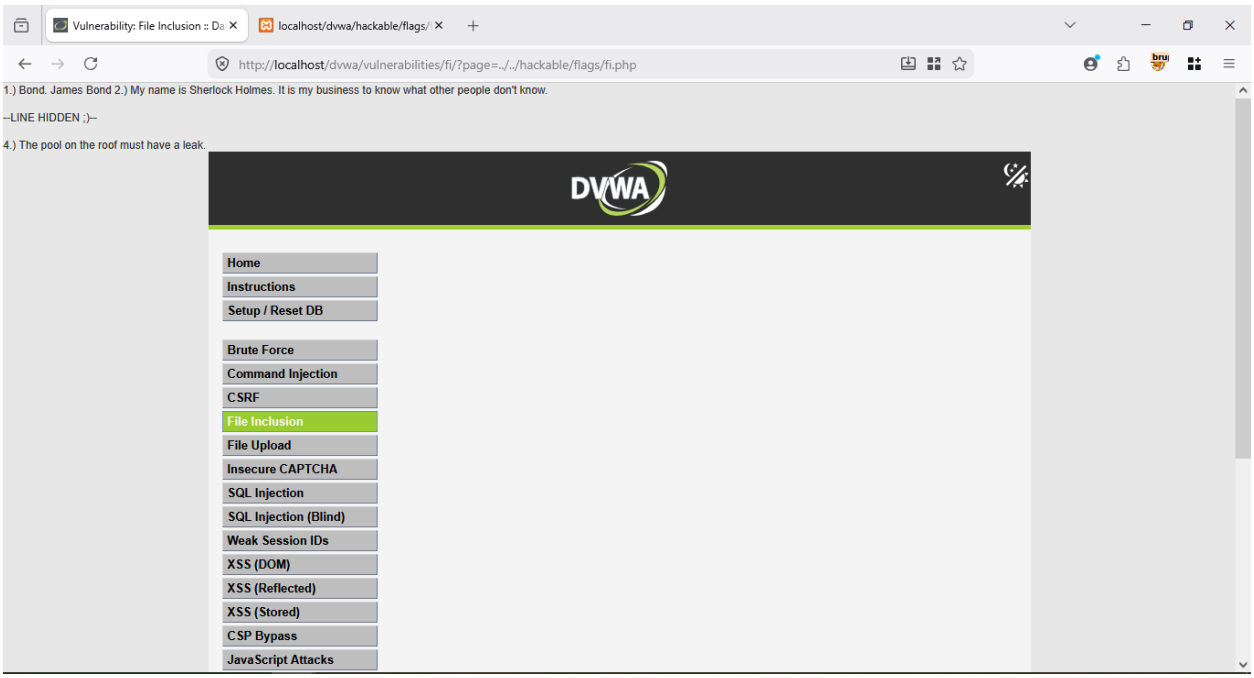
Kita bisa melihat terlebih dahulu isi file fi.php pada folder …/hackable/flags/fi.php



Menggunakan teknik direktori traversal (jenis serangan keamanan web yang memungkinkan penyerang mengakses file direktori dan perintah di luar folder root webserver yang diijinkan.

Berikut contoh serangannya:

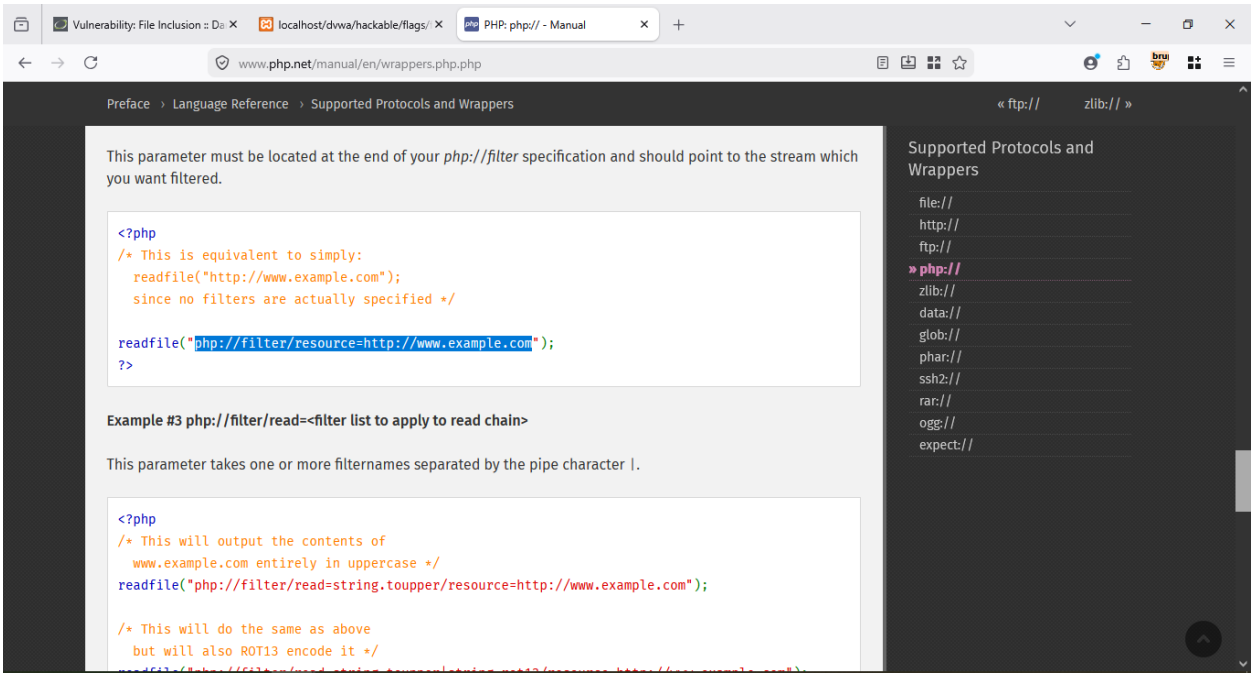
http://localhost/dvwa/vulnerabilities/fi/?page=../../hackable/flags/fi.php (level low)



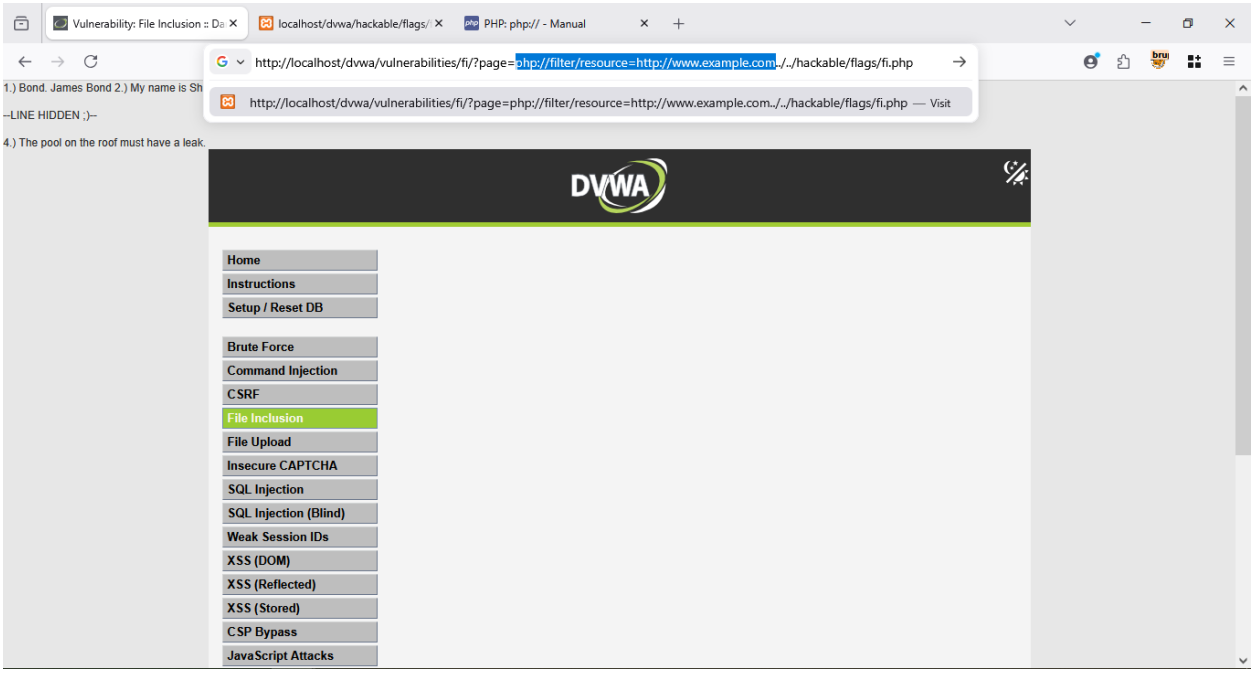
Jika kita lihat kita bisa mengkases quote 1,2 dan 4

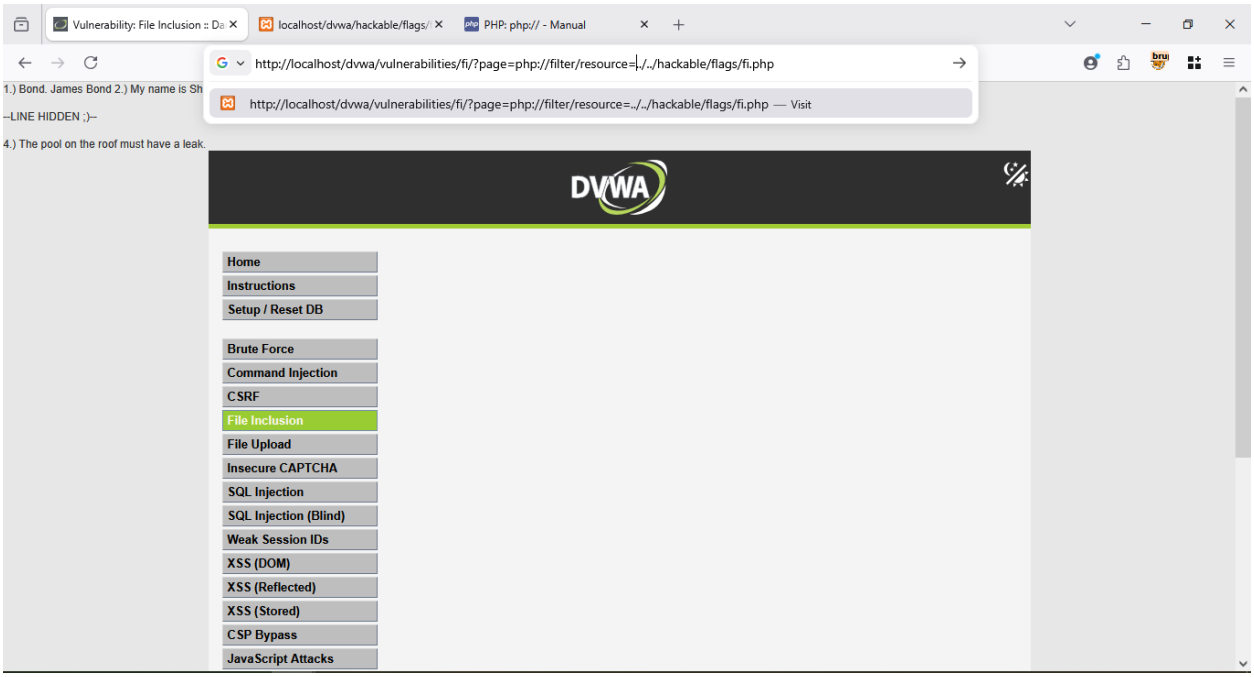
Kemudian kita akan mencoba mengakses quote ke 3 dengan menggunakan teknik php wrapper

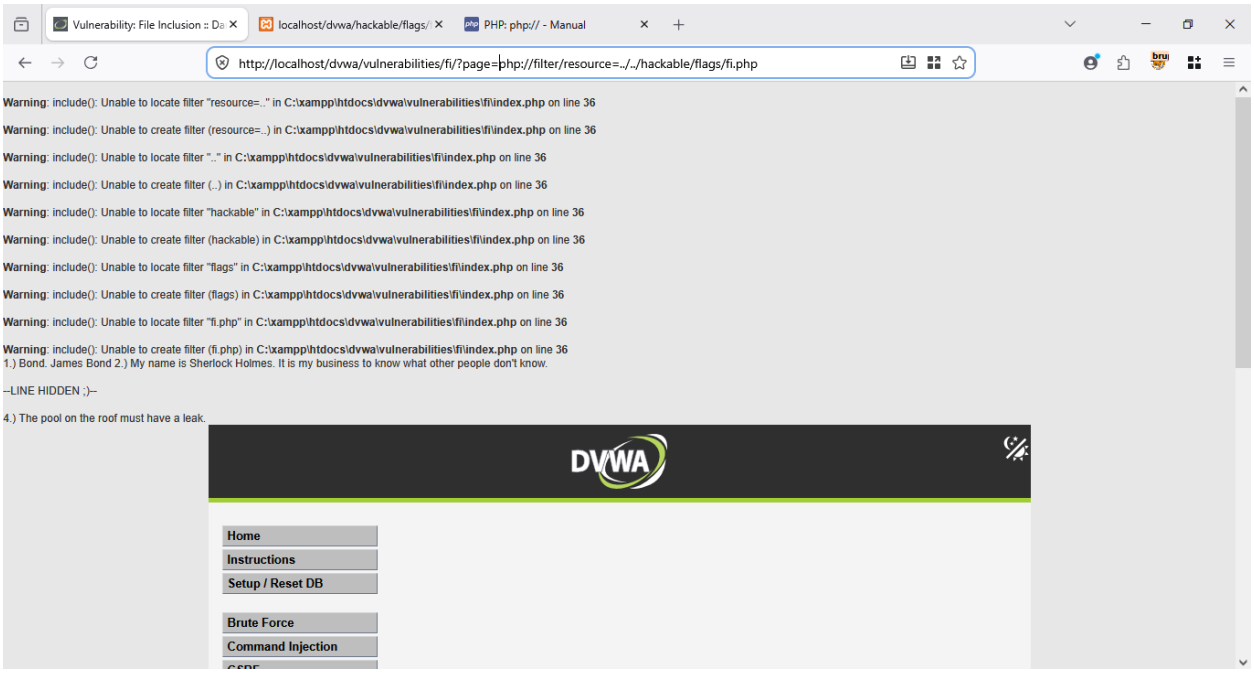
https://www.php.net/manual/en/wrappers.php.php



Kita copy code nya kemudian kita paste pada link sebelumnya seperti contoh di bawah kemudian hapus http://www.example.com

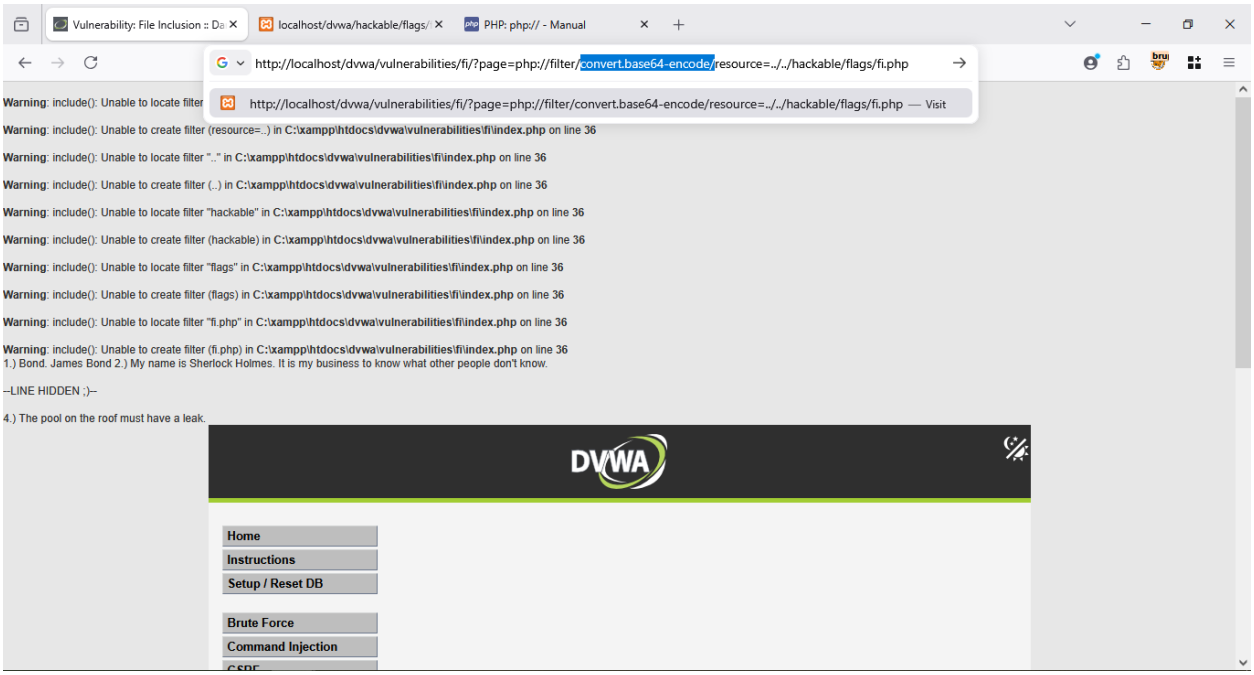




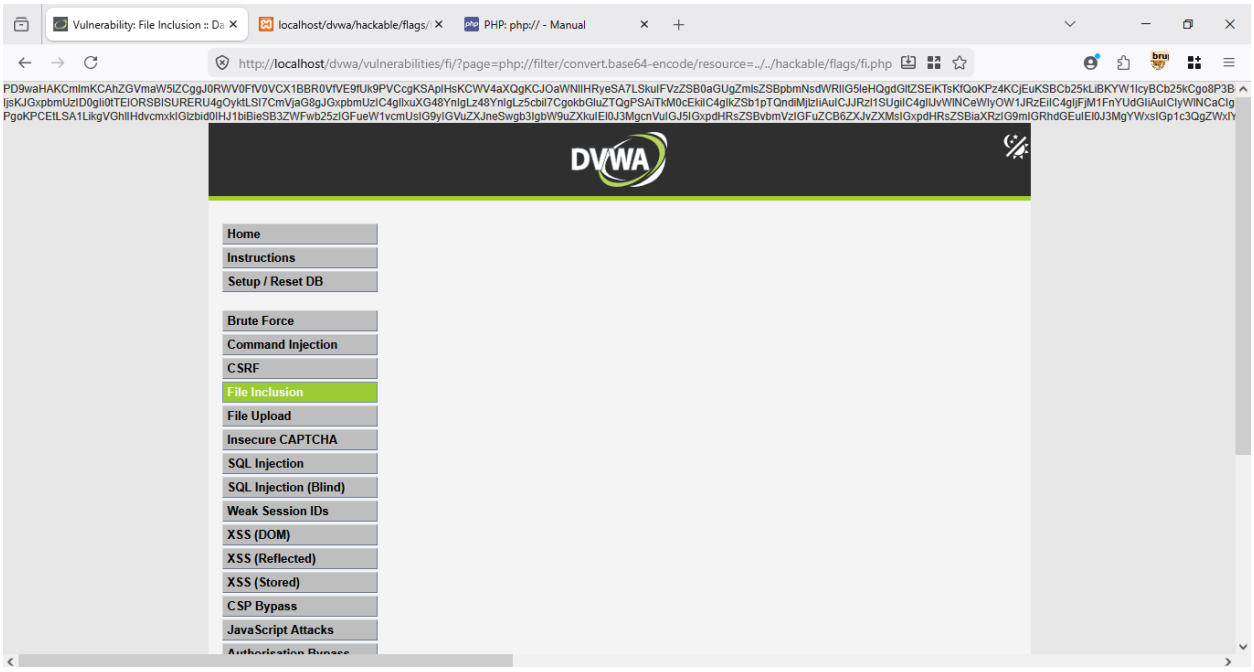


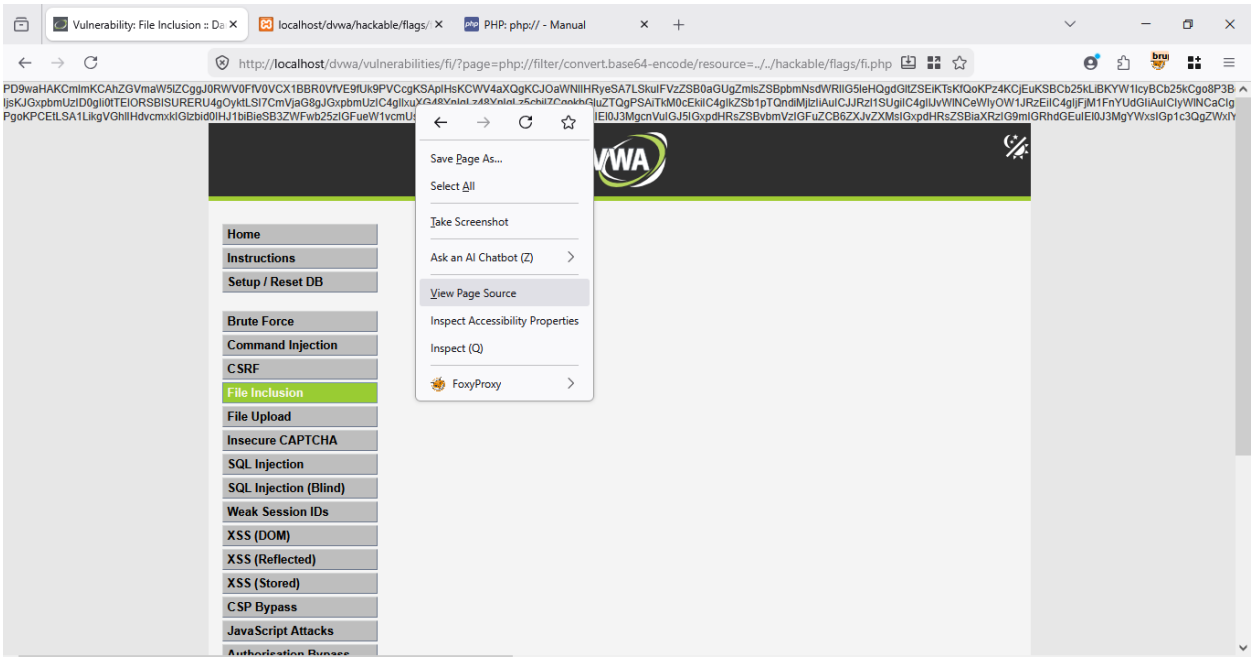
Kemudian kita juga gunakan teknik decoding tambahkan convert.base64-encode/ pada link sebelumnya.

Fungsi decode Base64 (sering dirujuk dalam konteks 64-bit atau base64) adalah proses untuk mengubah data yang telah dienkode (berbentuk string teks ASCII) kembali ke format data aslinya, baik itu teks biasa, biner, atau gambar.

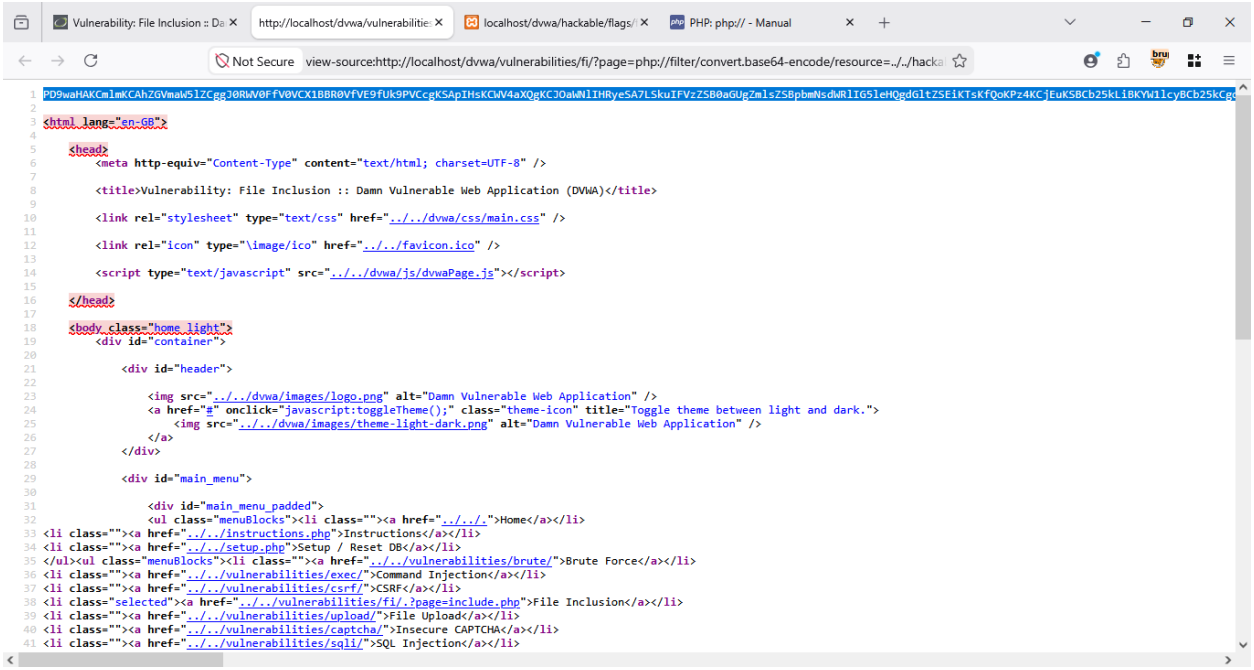


Maka akan muncul decode base 64 disini kita perlu melakukan encode untuk bisa membaca text aslinya

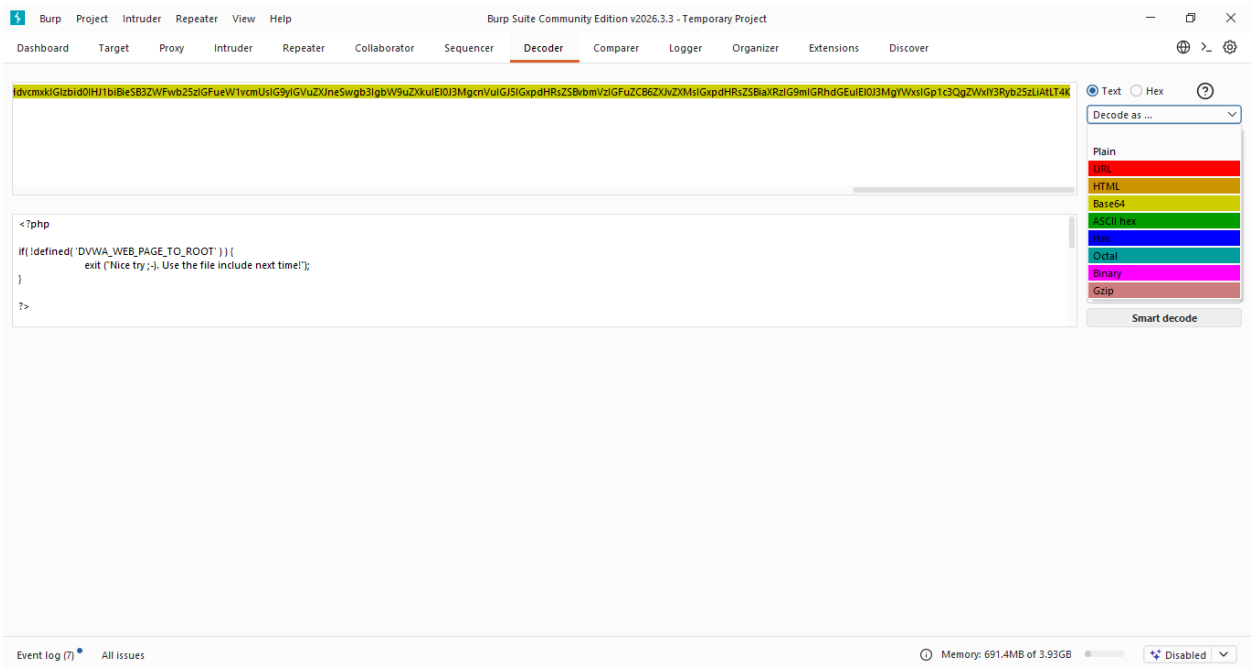




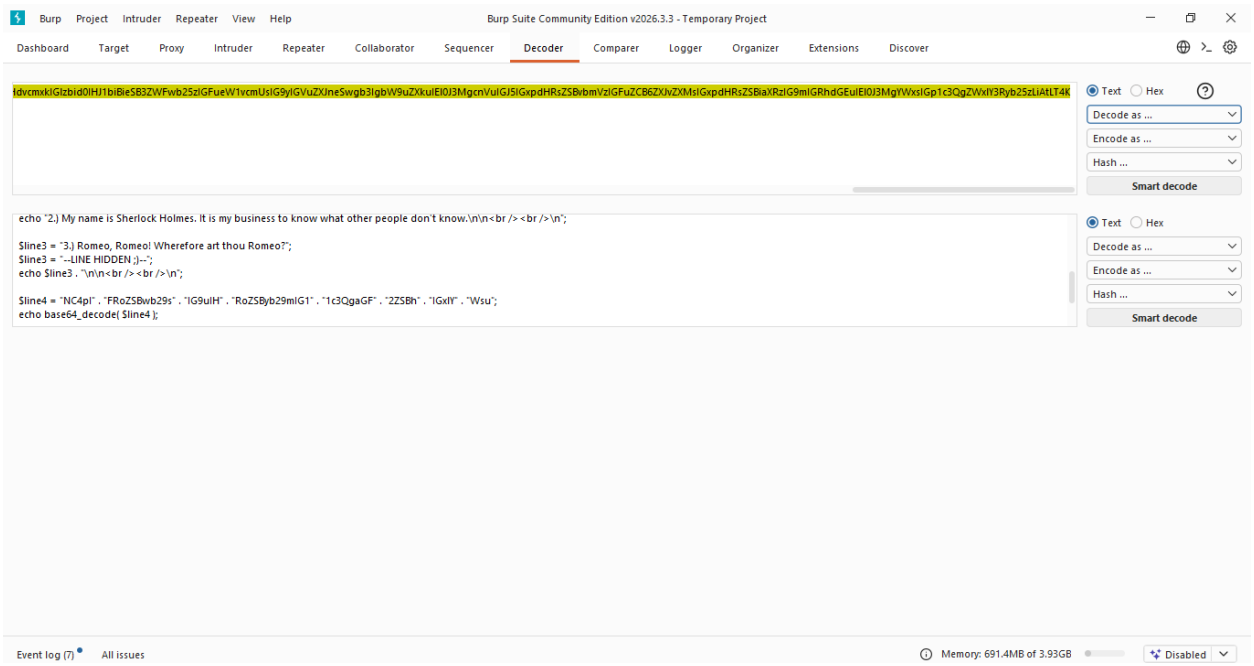
Kita copy hasil decode64



Buka aplikasi burp suite paste encode kemudian pilih base64



Kita berhasil mengakses quote ke 3



http://localhost/dvwa/vulnerabilities/fi/?page=....//....//hackable/flags/fi.php (level medium)

http://localhost/dvwa/vulnerabilities/fi/?page=file/../../../hackable/flags/fi.php (level high hanya sampai acces quote 1,2 dan 4)